

軟體品質保證 (SQA)

第四章：軟體檢視與靜態分析

授課教師：軟體品質保證教學團隊

4.1 軟體檢視 (Software Inspection)

4.1 軟體檢視 (Software Inspection)

- Fagan 檢視法的由來與價值
- 靜態檢視與動態測試的互補性
- 檢視的投資報酬率 (ROI)

Concept Check Question (CCQ 1)

針對「4.1 軟體檢視 (Software Inspection)」，下列何者敘述最為正確？

- **A.** 測試僅需在程式碼撰寫完成後由開發者單獨執行即可
- **B.** Fagan 檢視法的由來與價值 是確保系統品質的重要實踐
- **C.** 品質控制 (QC) 與品質保證 (QA) 完全等價且無區別
- **D.** 達到 100% 程式碼涵蓋率代表軟體絕對無任何缺陷



CCQ 1 - 答案與解析

正確答案：B

● 解析：

- 選項 B 正確：Fagan 檢視法的由來與價值 確實是軟體品質保證中的核心重點。
- 選項 A 錯誤：測試應貫穿整個軟體生命週期，且包含獨立測試與同儕檢視。
- 選項 C 錯誤：QC 著重於產品檢查與缺陷發現，QA 著重於流程建立與預防。
- 選項 D 錯誤：高涵蓋率不代表無邏輯錯誤或規格遺漏，無法保證絕對零缺陷。



4.2 檢視流程與角色

4.2 檢視流程與角色

- 檢視六大階段：計畫、簡報、準備、會議、重工、追蹤
- 角色分工：主持人、作者、閱讀者、記錄者
- 檢視會議的最佳實踐

Concept Check Question (CCQ 2)

針對「4.2 檢視流程與角色」，下列何者敘述最為正確？

- **A.** 測試僅需在程式碼撰寫完成後由開發者單獨執行即可
- **B.** 檢視六大階段：計畫、簡報、準備、會議、重工、追蹤 是確保系統品質的重要實踐
- **C.** 品質控制 (QC) 與品質保證 (QA) 完全等價且無區別
- **D.** 達到 100% 程式碼涵蓋率代表軟體絕對無任何缺陷



CCQ 2 - 答案與解析

正確答案：B

- 解析：

- **選項 B 正確**：檢視六大階段：計畫、簡報、準備、會議、重工、追蹤確實是軟體品質保證中的核心重點。
- **選項 A 錯誤**：測試應貫穿整個軟體生命週期，且包含獨立測試與同儕檢視。
- **選項 C 錯誤**：QC 著重於產品檢查與缺陷發現，QA 著重於流程建立與預防。
- **選項 D 錯誤**：高涵蓋率不代表無邏輯錯誤或規格遺漏，無法保證絕對零缺陷。



4.2.4 AI 輔助下的現代檢視實踐

- **AI 先行，人類把關：**
 - **AI 第一道防線：**在提交 PR 時，AI 機器人自動掃描低階錯誤（如變數未初始化、資源洩漏、基礎安全漏洞）並給出建議。
 - **人機協同複審：**人類審查員聚焦於 AI 無法涵蓋的全局架構、複雜商業邏輯與可靠性不變量。
- **角色工作型態轉變：**
 - **作者：**本地 IDE (Cursor / Copilot) 先行排查。
 - **記錄者：**AI 語音轉文字自動分類缺失與重工清單。
 - **審查員：**直接與 AI 對話，模擬極端輸入與邊界條件。

4.3 規格與設計檢視

4.3 規格與設計檢視

- 需求規格 (SRS) 檢視表
- 完整性、正確性與可追溯性
- 架構與詳細設計檢核重點

Concept Check Question (CCQ 3)

針對「4.3 規格與設計檢視」，下列何者敘述最為正確？

- **A.** 測試僅需在程式碼撰寫完成後由開發者單獨執行即可
- **B.** 需求規格 (SRS) 檢視表 是確保系統品質的重要實踐
- **C.** 品質控制 (QC) 與品質保證 (QA) 完全等價且無區別
- **D.** 達到 100% 程式碼涵蓋率代表軟體絕對無任何缺陷



CCQ 3 - 答案與解析

正確答案：B

解析：

- 選項 B 正確：需求規格 (SRS) 檢視表 確實是軟體品質保證中的核心重點。
- 選項 A 錯誤：測試應貫穿整個軟體生命週期，且包含獨立測試與同儕檢視。
- 選項 C 錯誤：QC 著重於產品檢查與缺陷發現，QA 著重於流程建立與預防。
- 選項 D 錯誤：高涵蓋率不代表無邏輯錯誤或規格遺漏，無法保證絕對零缺陷。



4.4 程式碼檢視與靜態分析工具

4.4 程式碼檢視與靜態分析工具

- 程式碼異味 (Code Smells) 識別
- 命名規範與可讀性
- 靜態分析工具 PMD / Checkstyle / SonarQube

Concept Check Question (CCQ 4)

針對「4.4 程式碼檢視與靜態分析工具」，下列何者敘述最為正確？

- **A.** 測試僅需在程式碼撰寫完成後由開發者單獨執行即可
- **B.** 程式碼異味 (Code Smells) 識別 是確保系統品質的重要實踐
- **C.** 品質控制 (QC) 與品質保證 (QA) 完全等價且無區別
- **D.** 達到 100% 程式碼涵蓋率代表軟體絕對無任何缺陷



CCQ 4 - 答案與解析

正確答案：B

- 解析：

- **選項 B 正確**：程式碼異味 (Code Smells) 識別 確實是軟體品質保證中的核心重點。
- **選項 A 錯誤**：測試應貫穿整個軟體生命週期，且包含獨立測試與同儕檢視。
- **選項 C 錯誤**：QC 著重於產品檢查與缺陷發現，QA 著重於流程建立與預防。
- **選項 D 錯誤**：高涵蓋率不代表無邏輯錯誤或規格遺漏，無法保證絕對零缺陷。



4.5 安全漏洞與 OWASP Top 10

4.5 安全漏洞與 OWASP Top 10

- 安全漏洞檢視：在程式碼檢視中攔截資安隱患
- **OWASP Top 10**：全球公認 Web 應用程式最關鍵的十大安全威脅
- 靜態分析 (SAST) 的安全檢視：
 - 使用工具自動化檢查不安全編碼
 - 提早發現注入、加密失效等問題

OWASP Top 10 核心漏洞清單 (2021)

- **A01: Broken Access Control** (權限控制失效)
- **A02: Cryptographic Failures** (加密機制失效 - 如弱金鑰/明文)
- **A03: Injection** (注入攻擊 - 如 SQL Injection, XSS)
- **A04: Insecure Design** (不安全設計)
- **A05: Security Misconfiguration** (安全設定錯誤)
- **A06: Vulnerable/Outdated Components** (使用有漏洞/過時元件)
- **A07: Identification and Authentication Failures** (認證失效)
- **A08: Software and Data Integrity Failures** (完整性失效)
- **A09: Security Logging and Monitoring Failures** (日誌失效)
- **A10: Server-Side Request Forgery** (SSRF 伺服器端請求偽造)

Concept Check Question (CCQ 5)

【是非題】在程式碼檢視中，若發現系統將詳細的例外錯誤堆疊資訊（如 `e.printStackTrace()`）輸出至前端或公開日誌，這屬於 A05:2021-安全設定錯誤 (Security Misconfiguration) 漏洞範疇。

- A. 正確 (True)
- B. 錯誤 (False)



CCQ 5 - 答案與解析

正確答案：A

- 解析：

- **正確**：生產環境輸出詳細的 Debug 資訊或錯誤堆疊（Stack Trace），會暴露系統元件版本、內部程式碼路徑及資料庫結構，屬於典型的「安全設定錯誤」。應使用結構化日誌（如 Logback/SLF4J）寫入後台受保護的日誌中。



本章重點回顧

本章小結與重點

- 掌握 **第四章：軟體檢視與靜態分析** 的核心概念與實務手法。
- 熟悉各項 SQA 技術在軟體生命週期中的應用時機與效益。
- 課後請完成隨堂練習與 Lab 實作，以深化觀念。

Q & A

謝謝大家！